ĐẠI HỌC QUỐC GIA HÀ NỘI

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

BÁO CÁO LUẬN VĂN THẠC SĨ

Ngành: Kỹ thuật phần mềm Mã số: 8480103.01

Hệ thống phát hiện Ransomware dựa trên Phân tích đa tầng, tích hợp Học tích cực và Kiểm chứng độ trung thực XAI

Học viên: Lưu Văn Doanh
GVHD: PGS.TS. Trương Ninh Thuận
Trường Đại học Công nghệ – ĐHQGHN

Ba đóng góp và bằng chứng thực nghiệm có thể truy nguyên

Hà Nội, 2026

Mạch trình bày

Bốn nội dung chính

1. Bài toán và khoảng trống nghiên cứu.
2. Kiến trúc và **ba đóng góp giữ nguyên**.
3. Bằng chứng thực nghiệm cho từng đóng góp.
4. Ý nghĩa, giới hạn và mức đóng góp tổng thể.

Nguyên tắc trình bày

- Không dùng Accuracy đơn lẻ để chứng minh hiệu quả.
- Mỗi số liệu truy về một artifact đã kiểm tra.
- Báo cả kết quả thuận lợi và kết quả chưa hỗ trợ giả thuyết.
- Nêu đúng quy mô của từng thực nghiệm và khoảng tin cậy.



Bài toán và động lực nghiên cứu

Bài toán vận hành

- Phân tích tĩnh nhanh, nhưng dễ suy giảm trước packing, obfuscation và API nạp động.
- Phân tích động quan sát được hành vi, nhưng tốn thời gian và tài nguyên.
- Hệ thống cần cập nhật trước mẫu mới mà không gán nhãn toàn bộ dữ liệu.
- Lời giải thích SHAP cần được kiểm tra bằng hành vi mô hình, thay vì chỉ trực quan hóa.

Câu hỏi nghiên cứu trung tâm

Làm thế nào kết hợp tín hiệu tĩnh–động, lựa chọn nhãn hiệu quả và kiểm chứng lời giải thích trong cùng một quy trình có thể đánh giá?

Hiệu năng phát hiện
AUC, AP, FPR/TPR

Chi phí vận hành
phân tích động, nhãn, overhead

Độ tin cậy giải thích
deletion và stability

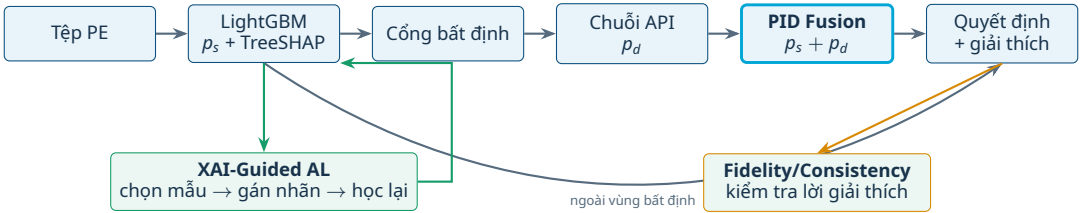
Khoảng trống nghiên cứu và điểm khác biệt

Hướng hiện có	Giới hạn thường gặp	Phần luận văn bổ sung
Dung hợp tĩnh–động	Trọng số cố định; khó phản ứng khi độ tin cậy thay đổi	**PID Fusion**: trọng số thay đổi theo bất đồng và trạng thái chuỗi
Active Learning	Chủ yếu dựa trên uncertainty xác suất	**XAI-Guided AL**: thêm Directional Entropy H và SHAP Variance V
SHAP cho mã độc	Thường dừng ở heatmap hoặc danh sách đặc trưng	**Fidelity Framework**: deletion control và độ ổn định thứ hạng
Đánh giá hệ thống	Nhấn mạnh một metric tổng hợp	Báo riêng ranking, low-FPR, chi phí nhãn và overhead

Phạm vi khoa học

Hệ thống hướng tới ransomware; bằng chứng hiện tại được đo trên dữ liệu mã độc Windows có nguồn và định danh. Không suy rộng sang ransomware/zero-day nếu nhãn nguồn chưa hỗ trợ.

Kiến trúc hệ thống đa tầng



PID
Điều chỉnh luật dung hợp

Active Learning
Tối ưu ngân sách nhãn

Fidelity
Kiểm tra chất lượng giải thích

Đóng góp 1 — Luật dung hợp PID theo chuỗi sự kiện

Cập nhật trọng số động

$$e_t = p_d(t) - p_s, \qquad u_t = K_p e_t + K_i \sum_{\tau \le t} e_\tau + K_d(e_t - e_{t-1})$$

$$w_{t+1} = \mathrm{clip}(w_t + u_t), \qquad p_f(t) = w_t p_s + (1 - w_t) p_d(t)$$

Trục thời gian là **số lời gọi API đã quan sát**: $t \in \{5, 10, 15, 20\}$, không phải số giây.

Vì sao cần ba thành phần?

- P: phản ứng với bất đồng hiện tại.
- I: tích lũy bất đồng có hệ thống.
- D: phản ứng với tốc độ thay đổi tín hiệu.

Cách chứng minh

Không suy luận hiệu quả từ công thức. So sánh Static, Dynamic, Average, Fixed, P, PI và PID trên cùng outer folds; dùng bootstrap ghép cặp cho chênh lệch.

Ba đóng góp của luận văn

1. PID Fusion

- Dung hợp p_s và p_d theo tiến trình.
- Ablation: Static, Dynamic, Fixed, P, PI, PID.
- Đo AUC/AP, FPR/TPR và độ nhạy.

Đã đo: cohort ghép cặp $n = 199$.

2. XAI-Guided AL

- $S = 0{,}3\hat{U} + 0{,}4\hat{H} + 0{,}3\hat{V}$.
- So Random, U, U+H, U+V, XAI-full.
- Đo AULC, budget-to-target và overhead.

Trạng thái: đã xác nhận.

3. Fidelity Framework

- Che top-|SHAP| và random cùng k.
- Mean/median baseline; $k = 10, 25, 50$.
- Đo deletion và rank stability.

Trạng thái: đã xác nhận.

Không tổng hợp OFS khi chưa có chuẩn hóa và trọng số chung được kiểm định; báo riêng từng thành phần để tránh điểm số tùy ý.

Thiết lập thực nghiệm có thể truy nguyên

AL và Fidelity — thực nghiệm xác nhận

- **2.000** dòng EMBER 2018; **2.381** đặc trưng.
- SHA-256 và feature hash đã đối chiếu theo từng dòng.
- 5 outer folds; 5 seed trong mỗi fold: **25** cặp fold–seed.
- Test không tham gia chọn mẫu, threshold hoặc tham số.

PID — thực nghiệm ghép cặp tĩnh–động

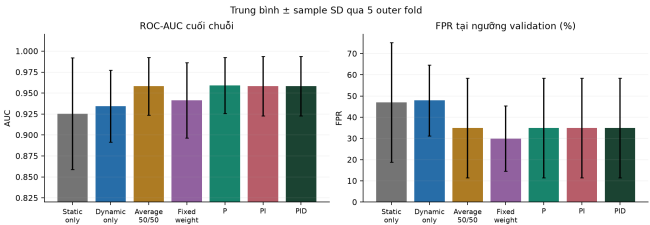
- MalBehavD-V1: **199/200** mẫu usable (100 benign, 99 malware).
- Kênh động: chuỗi API ở mốc 5, 10, 15, 20 sự kiện.
- Kênh tĩnh: 199 đặc trưng cấu trúc PE an toàn.
- 5 outer folds; bootstrap ghép cặp 1.000 lần.

Quy tắc đánh giá

Khóa split trước khi đo; chọn gain/trọng số/ngưỡng trên train–validation; lưu dự đoán từng mẫu, cấu hình, manifest và SHA-256 artifact; báo giới hạn dữ liệu cùng kết quả.

Nguồn: results/confirmatory_20261019_ember_identity; results/measured_20261020_malbehavd_pid_pilot200.

Đóng góp 1 — PID Fusion: kết quả trên 199 mẫu



Kết quả chính

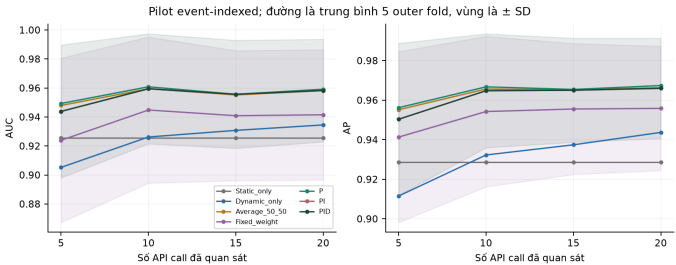
- Static: **0,9254** AUC.
- Dynamic: **0,9345** AUC.
- P: **0,9592**; PI/PID: **0,9583**.
- PID – Fixed: ΔAUC **+0,0130**; CI 95% $[-0,0086; +0,0409]$.
- ΔTPR **+4,10 pp**; ΔFPR **+5,06 pp**.

Diễn giải

Dung hợp thích nghi cải thiện ranking trên cohort này. PI và PID không đổi quyết định nào; dữ liệu hiện tại chưa chứng minh lợi ích riêng của thành phần D hoặc khả năng giảm FPR.

Nguồn: event_pid_table.tex; paired_bootstrap_pid_minus_fixed.json; $n = 199$, 5 outer folds.

PID Ablation — Thành phần nào tạo ra khác biệt?



So sánh AUC

- Static: **0,9254**.
- Dynamic: **0,9345**.
- Average: **0,9582**.
- Fixed: **0,9415**.
- P: **0,9592**.
- PI/PID: **0,9583**.

Kết luận ablation

Lợi ích chính đến từ **dung hợp hai nguồn** và phản ứng *P*. Với bốn mốc sự kiện, *I* và *D* chưa tạo khác biệt đo được; vì vậy không gán công lao giảm FPR cho PID đầy đủ.

Đóng góp 2 — Từ XAI đến quyết định gán nhãn

Điểm truy vấn

$$S(x) = 0{,}3\widehat{U}(x) + 0{,}4\widehat{H}(x) + 0{,}3\widehat{V}(x)$$

- U: bất định xác suất dự đoán.
- H: entropy hướng của đóng góp SHAP, đo xung đột giữa nhóm đặc trưng.
- V: độ phân tán độ lớn SHAP.

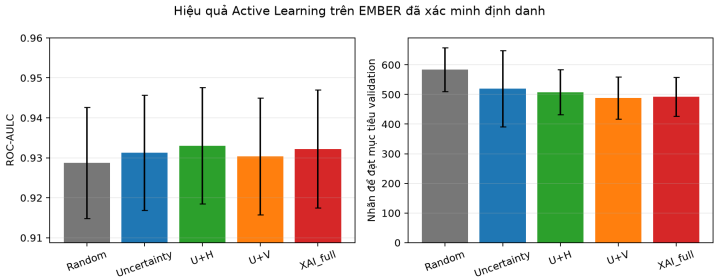
Thiết kế so sánh công bằng

- Cùng initial set, pool, batch và ngân sách.
- So Random, Uncertainty, U+H, U+V và XAI-full.
- Human-in-the-loop: chiến lược chỉ **chọn mẫu**; không tự sinh nhãn.
- Đo AULC, số nhãn tới mục tiêu và query overhead.

Giả thuyết kiểm chứng

Nếu tín hiệu giải thích hữu ích, chiến lược có H/V phải đạt cùng mức hiệu năng với ít nhãn hơn hoặc cải thiện toàn bộ đường học, thay vì chỉ tăng AUC ở vòng cuối.

Đóng góp 2 — XAI-Guided Active Learning



Hiệu quả sử dụng nhãn

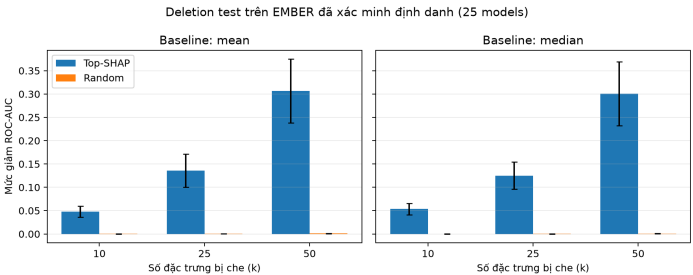
- XAI-full đạt mục tiêu với **492 nhãn**.
- Random: 584 ⇒ tiết kiệm **92 nhãn (15,8%)**.
- Uncertainty: 520 ⇒ tiết kiệm **28 nhãn (5,4%)**.

Chất lượng đường học

U+H – Random: ΔROC-AULC **+0,00425**; ΔAP-AULC **+0,01498**; thắng 5/5 folds. Overhead query của XAI-full: **5,42%** train+query.

Nguồn: al/aulc_summary.csv; target_reach_summary.csv; overhead_by_fold.csv; 25 cặp fold–seed.

Đóng góp 3 — Fidelity và độ ổn định của SHAP



Deletion test — mean baseline

- $k = 10$: top-SHAP **0,0478**; random 0,0002.
- $k = 25$: top-SHAP **0,1359**; random 0,0005.
- $k = 50$: top-SHAP **0,3067**; random 0,0010.

Consistency

Spearman thứ hạng: **0,614** trong fold và **0,551** giữa các fold. Kết quả cho thấy SHAP bám vào hành vi mô hình trong không gian đặc trưng EMBER.

Nguồn: fidelity/deletion_summary.csv; shap_stability_summary.csv; 25 models, mean/median masking.

Tiếp thu góp ý của Hội đồng Seminar

Góp ý Seminar	Nội dung đã bổ sung
Tách đóng góp từng thành phần	Ablation PID; U/H/V; top-SHAP so với random
Kết quả gán nhãn chưa thuyết phục	5 folds $\times$ 5 seeds; AULC, số nhãn tới mục tiêu, over-head
AUC tăng ít có ý nghĩa gì?	Chênh lệch ghép cặp, CI, AP và FPR/TPR
Độ đo XAI có phù hợp?	Mean/median masking, ba mức k, stability; không gộp OFS
Tổng thể hệ thống được gì?	Đối chiếu từng claim với artifact và ablation

Bằng chứng đã khóa trong deck

AL: đã xác nhận.

Fidelity: đã xác nhận.

PID: đã đo trên 199 mẫu ghép cặp.

Giới hạn phát biểu

- PID là bằng chứng thăm dò trên MalBehavD-V1, không đại diện riêng cho ransomware.
- Không tuyên bố thành phần D làm giảm FPR.
- Không gộp Fidelity thành OFS khi trọng số chưa được kiểm định.

Kết luận: Ba đóng góp và giá trị thực nghiệm

1. PID Fusion

Kết hợp tĩnh–động nâng AUC từ 0,9254/0,9345 lên khoảng 0,958–0,959. Trên cohort này, P đủ mạnh; lợi ích riêng của I/D chưa rõ.

2. XAI-Guided AL

XAI-full đạt mục tiêu với 492 nhãn: giảm 92 nhãn so với Random và 28 nhãn so với Uncertainty; U+H cải thiện AULC ở 5/5 folds.

3. Fidelity

Che top-50 SHAP làm AUC giảm 0,3067, trong khi random chỉ 0,0010; Spearman đạt 0,614 trong fold và 0,551 giữa fold.

Thông điệp chính

Giá trị của luận văn nằm ở ba phép kiểm chứng bổ sung cho nhau: dung hợp hai nguồn tín hiệu, giảm chi phí nhãn và kiểm tra lời giải thích bằng hành vi mô hình. Kết quả được báo theo artifact, ablation và khoảng tin cậy thay vì dựa vào một con số Accuracy.

Xin trân trọng cảm ơn Hội đồng!